Cybersecurity Daily Newsletter

Vol. 006 | 2026-10-23 09:00 WIB

Top 5 Highlights

• Arista Networks patches actively exploited zero-day vulnerability in VeloCloud Orchestrator

• Microsoft links agentic AI to ConnectWise supply chain breach

• 2026-10-16: Coruna-like iOS exploit kit traffic

• VU#763488: Memory corruption vulnerabilities in PHP

• The adversary economy: How threat actors are reacting to PHP2Shell

Threat Intelligence (10)

01. Microsoft Links Storm-0940 to ConnectWise Supply Chain Attack

The China-linked actor used an AI-enabled penetration-testing tool to automate and accelerate its attack on more than 2,200 tenants.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: https://www.darkreading.com/cyberattacks-data-breaches/microsoft-storm-0940-connectwise-supply-chain-attack

02. What We Missed: Feds Lasso Texas Laptop Farms

In this video, Dark Reading editors discuss some of the news they didn't get a chance to cover, from busting up North Korea's stateside infrastructure in "Operation Lonestar Justice" to Staples' gift card bonanza.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.darkreading.com/insider-threats/texas-laptop-farms-north-korean-it-workers

03. LiteLLM release pipeline hacked to distribute info-stealer malware

Hackers compromised the LiteLLM project's PyPI package and published malicious Docker images with a payload that steals credentials, secrets, and environment variables. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.bleepingcomputer.com/news/security/litellm-release-pipeline-hacked-to-distribute-info-stealer-malware/

04. The AI Agent Nobody Owns: Watch Expert Webinar On Your Newest Insider Threat

Right now, there is probably an AI agent running on a laptop somewhere in your network. It stores API keys and database passwords, can access your internal systems, and works without anyone watching. Nobody reviewed its access. Nobody owns it. If an employee had that much reach with that little oversight, you would call it an insider risk. So why do we stil...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://thehackernews.com/2026/10/the-ai-agent-nobody-owns-watch-expert.html

05. When the attacker becomes the user: Rethinking account takeover

SPONSORED FEATURE: AI makes phishing easier than ever

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://www.theregister.com/security/2026/10/22/sponsored-when-the-attacker-becomes-the-user-rethinking-account-takeover/5303913

06. LiteLLM hit by second supply chain attack this year, users urged to rotate credentials

A malicious release of LiteLLM pushed to PyPI and Docker registries on Wednesday carried malware built to harvest cloud logins, developer secrets and API keys for AI services from anyone who installed it. “LiteLLM got compromised… again,” security researcher Kevin Beaumont wrote on Mastodon. In August, Hudson Rock analyzed a 153GB archive stolen during an e…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: https://www.helpnetsecurity.com/2026/10/22/litellm-compromised-supply-chain-attack-pypi-docker/

07. Iranian Hacking Group Found Hosting C2 Infrastructure in the US

Stealthy malware campaign by ‘Prince of Persia’ threat group targeting organisations worldwide discovered operating on American soil

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.infosecurity-magazine.com/news/iranian-hacking-group-hosting-c2/

08. Localizing compliance at scale: achieving South Korea’s ISMS certification

Cloudflare has achieved South Korea's ISMS certification following an audit across 80 controls. Learn how we localized user consent flows, adapted social sign-up paths at the edge, and validated our global security program.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://blog.cloudflare.com/k-isms/

09. Cyber Threat Context for Early Response: Enriching SOC Telemetry with Real-Time Intel from 16K Organizations

When an IOC hits the SOC, the clock is already running. An IP address, domain, file hash, or suspicious URL can trigger a detection, but an analyst still needs to understand what it is, whether it is connected to known malicious activity, and what happened around it. The longer it takes to build that context, […] The post Cyber Threat Context for Early Resp…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://any.run/cybersecurity-blog/cyber-threat-context-for-early-soc-triage-response/

10. LiteLLM release pipeline hacked to distribute credential-stealing malware

Hackers hijacked the software release pipeline of LiteLLM, a popular open-source AI gateway, to distribute credential-stealing malware, marking the project’s second supply chain compromise this year despite security measures introduced after an earlier attack. The compromised version, 1.107.0, was distributed through the Python Package Index (PyPI) and offi…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: https://www.csoonline.com/article/4239033/litellm-release-pipeline-hacked-to-distribute-credential-stealing-malware.html

Latest Vulnerabilities (10)

01. Arista Networks patches actively exploited zero-day vulnerability in VeloCloud Orchestrator

Arista Networks has released critical security updates to address an actively exploited zero-day vulnerability affecting VeloCloud Orchestrator on-premises deployments, according to a recent report by Bleeping Computer.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/brief/arista-networks-patches-actively-exploited-zero-day-vulnerability-in-velocloud-orchestrator

02. 2026-10-16: Coruna-like iOS exploit kit traffic

2026-10-16: Coruna-like iOS exploit kit traffic

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.malware-traffic-analysis.net/2026/10/16/index.html

03. VU#763488: Memory corruption vulnerabilities in PHP

Overview Two memory-related vulnerabilities have been identified in PHP versions prior to 8.2.35, 8.3.36, 8.4.27, and 8.5.12. An unauthenticated remote attacker with network access to PHP web services can exploit these vulnerabilities via specially crafted HTTP requests to potentially achieve arbitrary code execution. Description PHP is a widely used open-s...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://kb.cert.org/vuls/id/763488

04. The adversary economy: How threat actors are reacting to PHP2Shell

Two critical PHP vulnerabilities sent criminal forum operators scrambling to protect their own infrastructure, revealing that threat actors face the same exposure management challenges as the organizations they target. Key takeaways The adversary economy operates on the same fundamental principles as the legitimate economy. Forum self-evacuations: Criminal...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.tenable.com/blog/php2shell-vulnerability-threat-actor-response

05. PHP2Shell exploit bypasses protections designed to stop remote code execution

“Adversaries are clearly spending time (and tokens) on this bug,” researcher says.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.theregister.com/security/2026/10/22/php2shell-exploit-bypasses-protections-designed-to-stop-remote-code-execution/5304883

06. GitLab critical patches include one for a bug that allows code execution by unauthenticated users

GitLab on Wednesday published updated versions of its Community Edition (CE) and Enterprise Edition (EE) that address a dozen bugs and security issues, including some that allow various unauthenticated actions. The most serious of the security issues, labeled critical in severity, is CVE-2026-110264 , an integer overflow issue. “GitLab has

remediated an iss…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.csoonline.com/article/4239289/gitlab-critical-patches-include-one-for-a-bug-that-allows-code-execution-by-unauthenticated-users-2.html

07. Les supermarchés de l'UE paient d'un firmware de réfrigérateur non mis à jour

Des centaines de magasins ont subi des pertes se chiffrant en millions d'euros parce qu'ils avaient fait appel à des tiers pour gérer le micrologiciel OT obsolète qui pilotait leurs systèmes de climatisation.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.darkreading.com/ics-ot-security/eu-grocers-unpatched-fridge-firmware-french

08. Arista Warns of Critical VeloCloud SQL Injection Zero-Day Exploited in Attacks

Attackers are exploiting a zero-day SQL injection flaw in Arista's VeloCloud Orchestrator (VCO), the central management system for VeloCloud SD-WAN networks, the company said in an advisory on October 22. The flaw lets anyone who can log in to the orchestrator, even with a read-only customer account, gain operator privileges, the top level of control over i…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://thehackernews.com/2026/10/arista-warns-of-critical-velocloud-sql.html

09. Security teams urged to center defense on the flaw profile attackers target most

Attackers are increasingly focusing on a limited range of critical vulnerabilities to run attacks with flaws packaged into exploits within as little as three days. Rapid7’s latest Quarterly Threat Landscape report found the number of newly exploited vulnerabilities in Q3 of 2026 was 43, up 19% year on year. Douglas McKee, director of vulnerability intellige…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.csoonline.com/article/4239255/security-teams-urged-to-center-defense-on-the-single-profile-attackers-target-most.html

10. Max-severity GitLab bug allows remote code execution over 12 years of releases

Vendor 'strongly recommends' upgrading to a fixed version 'as soon as possible'

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.theregister.com/security/2026/10/22/max-severity-gitlab-bug-allows-remote-code-execution-over-12-years-of-releases/5304854

Data Breach & Cybercrime (10)

01. Microsoft links agentic AI to ConnectWise supply chain breach

CRN reports that the China-aligned threat group Storm-0940 utilized agentic artificial intelligence to execute a large-scale supply chain compromise targeting ConnectWise Cloud Backup users.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.scworld.com/brief/microsoft-links-agentic-ai-to-connectwise-supply-chain-breach

02. Railway warns devs to rotate secrets after potential breach

Cloud platform Railway published an urgent warning to users after detecting suspicious activity on its systems that store customer environment variables earlier this week. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.bleepingcomputer.com/news/security/railway-warns-devs-to-rotate-secrets-after-potential-breach/

03. Capcom confirms data breach affecting 11.7 million accounts

Japanese gaming giant Capcom has confirmed that hackers breached its membership service, CAPCOM ID, exposing more than 11.7 million customer email addresses and associated information. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.bleepingcomputer.com/news/security/capcom-confirms-data-breach-affecting-117-million-accounts/

04. ThreatsDay: AI Secrets Leak, PingCAP Source Theft, Signal Hang-Up Flaw, Laravel Auth Bypass + 21 More

This week has already been rough for cybersecurity. Critical PHP and GitLab RCE flaws, serious Linux security bugs, compromised eMudhra certificates, a Node.js RCE flaw, a hacked LiteLLM release, and hundreds of hijacked Tor relays. That's a lot to deal with in just a few days. And the week isn't even over yet. But those big headlines are only half the stor…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://thehackernews.com/2026/10/threatsday-ai-secrets-leak-pingcap.html

05. Scammers are finding new ways to target your phone. Here are 5 ways to protect yourself

One in three people now tune out scam warnings, and scammers are counting on it.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.malwarebytes.com/blog/scams/2026/10/scammers-are-finding-new-ways-to-target-your-phone-here-are-5-ways-to-protect-yourself

06. EU Regulators to Investigate Booking.com Over Scam Risks

The EU Commission will assess whether Booking.com has adequately protected customers from phishing attacks

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.infosecurity-magazine.com/news/eu-bookingcom-scam-risks/

07. INTERPOL Arrests 1,462 Suspects, Disrupts 10,909 Cybercrime Networks in Global Crackdown

INTERPOL on Thursday announced that a coordinated law enforcement action has disrupted 10,909 malicious networks and recovered more than $105 million in illicit funds. In tandem, the effort saw law enforcement agencies from 21 countries arrest 1,462 suspects. Codenamed Operation Serengeti III, the cybercrime crackdown took place between June 29 and August 3…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://thehackernews.com/2026/10/interpol-arrests-1462-suspects-disrupts.html

08. Fingerprint uses AI coding tools to automate fraud detection setup

Fingerprint has announced Agentic Installation, the AI-powered onboarding path for companies to deploy device intelligence to their websites or apps in minutes to detect and stop fraud. By running a single prompt in an AI coding tool, such as Claude Code, Codex or Cursor, developers take Fingerprint from zero to production-ready in minutes, reducing manual…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.helpnetsecurity.com/2026/10/22/fingerprint-agentic-installation/

09. Microsoft says ConnectWise breach let Chinese spies loose on 2,250 cloud tenants

AI agents did the dirty work, with hackers gaining privileged access in some environments in under three hours

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.theregister.com/security/2026/10/22/microsoft-says-connectwise-breach-let-chinese-spies-loose-on-2250-cloud-tenants/5304687

10. Woman faces years in prison over a Cash App account she says she never opened

A woman faces up to six years in prison over a Cash App account she says someone opened using her stolen identity.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.malwarebytes.com/blog/news/2026/10/woman-faces-years-in-prison-over-a-cash-app-account-she-says-she-never-opened